

RANSOMWARE 2026

Inside the Criminal Enterprise

How the business works – and how to fight back

Version: 1.2

Author: Sylvain Martinez

Classification: PUBLIC

{**elysium**security}
cyber protection & response

Inside the ransomware business: How attacks are run, why victims pay, and what reduces both risk and impact.



1. CONTEXT:

THE SCALE AND EVOLUTION OF THE THREAT

2. BLUEPRINT:

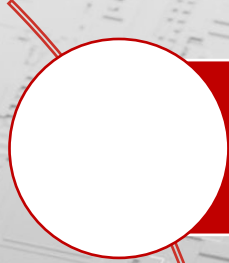
HOW THE CRIMINAL BUSINESS WORKS

3. DEFENCE:

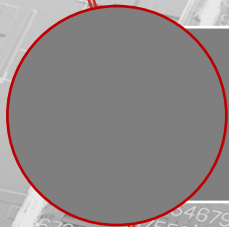
HOW TO FIGHT BACK

4. NEXT:

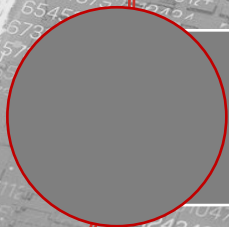
YOUR RANSOMWARE READINESS CHECKLIST



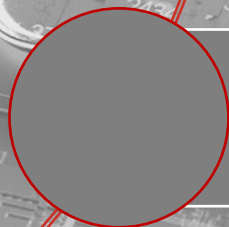
CONTEXT



BLUEPRINT



RESPONSE



NEXT

\$820M

Cybercrime revenue
2025

*down 8% from 2024
based on blockchain tracing
Source: Chainalysis.com*

24%

Organisations hit
in 2025

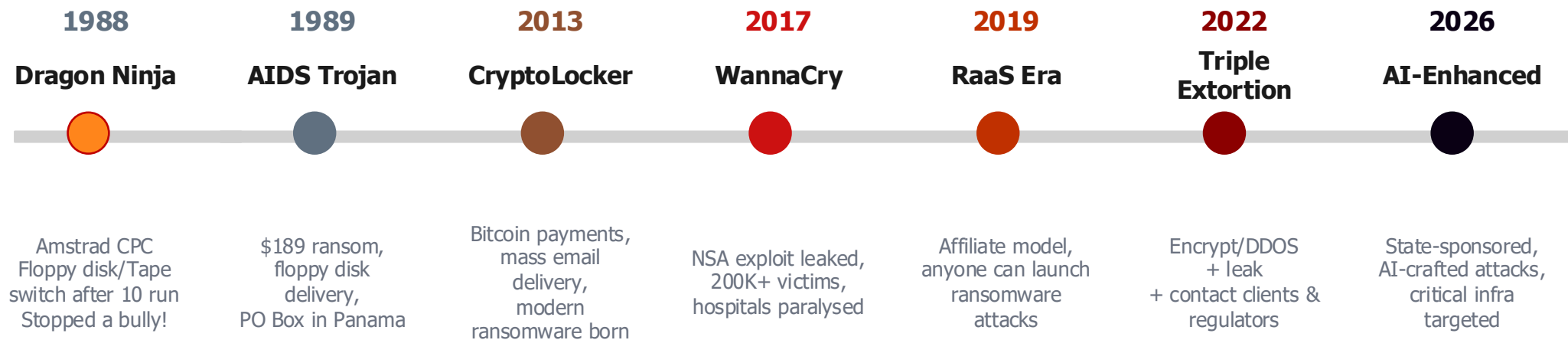
*up 19% from 2024
Source: hornetsecurity.com*

8 days

Average recovery
time after hit

*When a decryption key is available!
Source: Veeam.com*

Near \$1T in cybercrime revenue means ransomware is no longer just an IT problem - it is a board-level risk.
For context: more than the GDP of the Netherlands and 100x the GDP of Mauritius



2026 reality: Groups now use AI to craft full Ransomware solutions, operate 24/7 support desks, and target African and Indian Ocean markets that were previously ignored: no longer just collateral damage

Historically ignored. Now actively targeted — the economics have shifted:



Rapid digital growth

Mobile money, digital banking adoption, cloud migration — large, fast-growing target surface



Lower defensive maturity

Fewer cybersecurity professionals per capita, less mature SOC's, less budget



Limited Law Enforcement cooperation

Fewer cross-border prosecutions, lower risk of arrest for attackers



Lower insurance penetration

More organisations pay directly out of pocket - higher conversion rate for attackers (debatable)



Western markets hardened

Groups have shifted focus — Europe and US defences are now costlier to overcome



Regulatory pressure

DPA equivalent fines stack on top of the ransom - attackers weaponise your compliance exposure

Mauritius fits the profile attackers want: high-value organizations, growing digital exposure, and strong extortion leverage.

THE TARGET PROFILE

- International financial hub - high-value institutions
- SWIFT-connected banks - cross-border attack value
- Offshore structures - complex confidential data
- Fintech sector - rapid growth, mixed maturity
- Mobile money adoption - high consumer exposure
- Multiple listed entities - extortion leverage
- Hospitals & healthcare networks - patient data

REGIONAL INCIDENTS IN RECENT YEARS

- Central banks in several African nations
- Hospital networks - East & West Africa
- Shipping & port authorities (IO region)
- Government agencies - data leaks
- Telecoms operators - service disruption
- Payment processors - fraud + extortion

(tip of the iceberg)

The issue is not whether ransomware reaches Mauritius. The issue is how prepared your organisation is when it does.



CONTEXT

BLUEPRINT

DEFENCE

NEXT

RaaS operates like a franchise — three key roles + supporting ecosystem:



37%

PHISHING

Malicious email attachments or links. Increasingly AI-generated, personalised to the victim. Bypasses most technical controls because humans click.
19% = malicious, 18% = phishing

32%

KNOWN VULNERABILITIES

Unpatched public-facing systems exploited within hours of CVE publication. Automated scanners find victims before they patch. No sophistication required.

23%

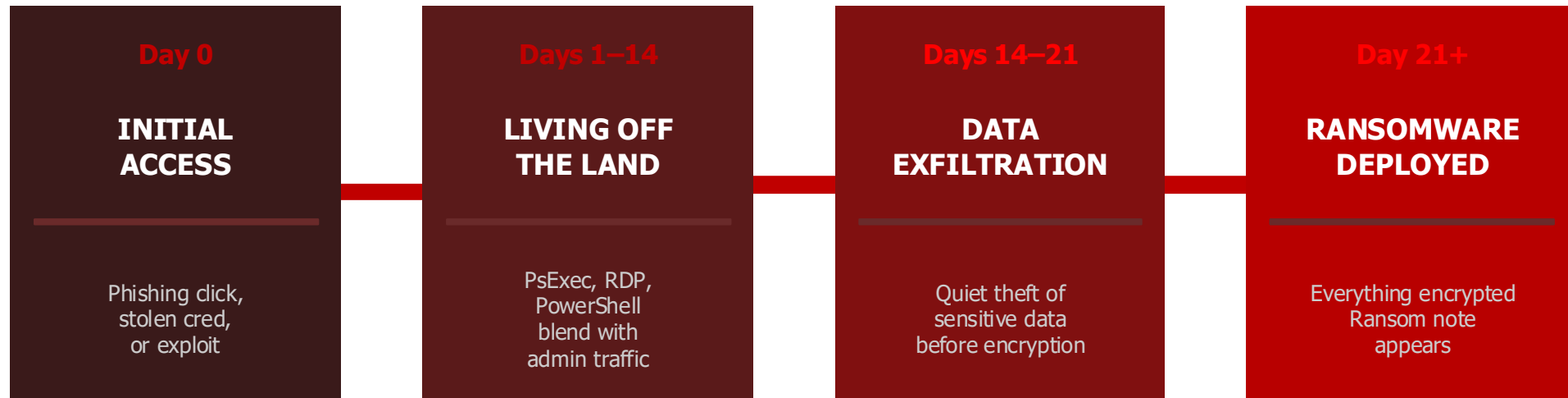
STOLEN CREDENTIALS

Bought from Initial Access Brokers or credential leak databases. Valid VPN or RDP logins acquired for as little as \$20 on dark web markets.

The hard part is no longer developing the malware. It is finding one path in - then scaling the attack.

Source: Sophos, The State of Ransomware 2025.

By the time the ransom note appears, attackers have been inside for weeks:



⚠ BY THE TIME THE RANSOM NOTE APPEARS:

*Your backups have been identified and targeted · Your most sensitive data has been stolen
Your domain controllers are compromised · Your network is fully mapped*

Note that AI is accelerating the time from initial access to Ransomware deployed to near 0 days
(maybe having a slow network will be a defense mechanism in the future!)

Modern ransomware uses three stacked pressure mechanisms:

L1	ENCRYPT YOUR DATA + DDOS Pay or lose access to your systems and data forever.	MITIGATION Tested immutable offline backups and DDoS protection
L2	LEAK YOUR DATA Pay or we publish on our dark web site - clients, regulators, media notified.	MITIGATION Data classification, DLP, breach notification readiness
L3	CONTACT YOUR CLIENTS Pay or we directly contact your customers and regulators.	MITIGATION Encrypt your data and Prepared crisis communications

⚠ Payment may help with decryption. It does not erase data theft, legal exposure, or the risk of being targeted again.

A realistic timeline of the first 72 hours after ransom note appears:



HOUR
0-2

Discovery

Staff cannot access files. Screens display ransom notes. IT team confirms encryption. Crisis mode begins.



HOUR
2-8

Command centre

CEO, CFO, CISO, Legal, PR, IT convene. Incident responders engaged. Insurer notified. Law enforcement contact initiated.



HOUR
8-24

Negotiation begins

Professional negotiator contacted. Proof-of-life request. Ransom demand analysed. Payment decision framework activated.

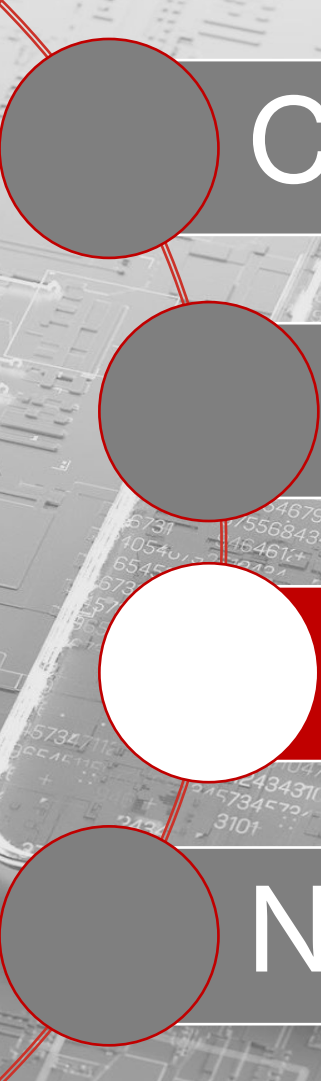


DAY
1-3

Recovery assessment

Backup integrity verified. Scope of data exfiltration assessed. Regulatory notification timelines activated. Client communication prepared.

Without a rehearsed playbook, the first 24 hours are disorder. With one, they become managed crisis response.



CONTEXT

BLUEPRINT

DEFENCE

NEXT

Four controls that would prevent or severely limit most ransomware:

01**Patch Fast**

32% of attacks exploit known CVEs

Patch critical internet-facing systems within 48 hours of CVE publication. Automate where possible.

02**MFA Everywhere**

Stolen creds useless with MFA

Enable MFA on ALL remote access: VPN, RDP, M365, cloud admin portals. No exceptions. Hardware keys for privileged accounts.

03**Segmentation**

Limit lateral movement blast radius

Ransomware should not reach everything from a single compromised workstation. Separate backup networks from production.

04**Immutable Backups**

Your ultimate insurance policy

3-2-1 rule: 3 copies, 2 media types, 1 offsite. Test restore MONTHLY. Air-gapped or immutable, otherwise attackers delete them first.

Most ransomware events still succeed because basics were incomplete, inconsistent, or not tested.

You have a time limited detection window. Watch for these pre-ransomware signals:

**Unexpected admin tool use**

Mimikatz, PsExec, Cobalt Strike, BloodHound on non-admin workstations: credential harvesting and lateral movement tools

**Bulk file enumeration**

Single account accessing 50,000 files it doesn't normally touch: the classic exfiltration precursor

**Off-hours privileged activity**

Admin-level activity at 3am from a user who normally works 9-5: attackers often operate across time zones

**Large outbound data transfers**

Hundreds of GB leaving to Mega, pCloud, unusual IPs: quiet data exfiltration before encryption day

DETECTION REQUIRES

EDR on all endpoints - Properly tuned SIEM rules - 24/7 SOC coverage or managed MDR service

These decisions must be made BEFORE the attack — not during it:



Written Playbook - Tested!

Documented response procedures with decision trees. Roles assigned. Escalation paths defined. Tested quarterly via tabletop exercises.



Legal Counsel On Retainer

Law firm experienced in cyber incidents. Pre-negotiated engagement. First call within 60 minutes of detection.



Negotiation Firm

Professional ransom negotiators. Typically reduce demands 30-60%. Buy time for technical recovery. Never negotiate yourself.



IR Retainer

Specialist incident response team pre-engaged. 24/7 SLA. Forensics, containment, eviction, recovery: all covered.



Crisis Communications

Pre-drafted templates for: customers, regulators, staff, media. Approved by legal. Sitting ready in shared location.



Payment Decision Framework

Written criteria for pay/no-pay decision. Board-level escalation defined. OFAC sanctions check built into process.

One of the hardest question in cybersecurity:

ARGUMENTS FOR PAYING

- ✓ Fastest path to operational recovery (maybe)
- ✓ Some groups honour decryption keys
- ✓ May be cheaper than full IT recovery effort
- ✓ If backups failed, possibly no other option
- ✓ Negotiation reduces demand 30-60% typically

ARGUMENTS AGAINST PAYING

- X No guarantee of working decryption key
- X Funds future criminal activity
- X Legal risk, OFAC sanctions on some groups
- X Does NOT prevent the data leak (L2)
- X Marks you as payer: higher re-attack rate

⚠ Do not make your payment policy for the first time in the middle of an incident.
Decide it, document it, and escalate it now.

Once the basics are in place, focus on these resilience multipliers:



Security Awareness

Regular phishing simulations with feedback loops. Role-specific training: finance & HR teams get targeted training for BEC and payroll fraud scenarios.



Zero Trust Architecture

Move beyond perimeter security. Every access request verified continuously. Especially important for hybrid and remote workforces.



Threat Intelligence

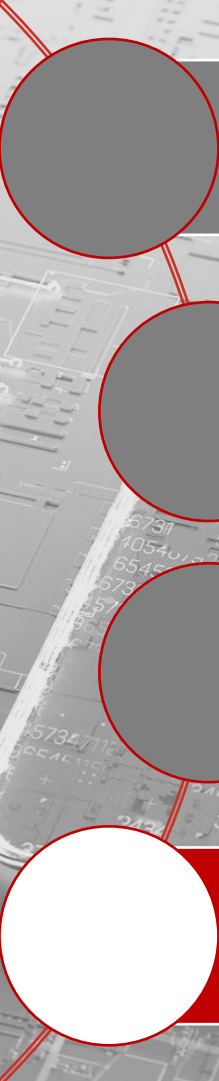
Subscribe to threat feeds relevant to your sector and region. Join local Intelligence organisations. Know what groups target your industry this month.



Tabletop Exercises

Run ransomware scenarios quarterly at board and executive level. Build muscle memory. Identify gaps. Refine the playbook continuously.

Resilience is built before the incident, then measured under pressure.



CONTEXT

BLUEPRINT

DEFENCE

NEXT



TODAY

- Verify MFA is enabled on VPN, RDP, M365, cloud admin portals
- If any remote access lacks MFA: treat as critical, fix today
- Confirm EDR is installed and alerting on ALL endpoints



THIS WEEK

- Test backup restore: actually restore a file from backup
- Confirm backups are offline/air-gapped and not reachable from network
- Verify most recent backup is less than 24 hours old



THIS MONTH

- Draft/Review ransomware playbook: escalation, legal, negotiation, decision framework
- Pre-identify IR retainer, legal counsel, negotiation firm
- Schedule quarterly tabletop exercise with board & execs

"Assume compromise. Limit spread. Recover with discipline. Speed and preparation decide the outcome."

THANK YOU!

Any Questions?



ABOUT ELYSIUMSECURITY LTD.

ELYSIUMSECURITY PROVIDES A PORTFOLIO OF **STRATEGIC** AND **TACTICAL SERVICES** TO HELP COMPANIES **PROTECT** AND **RESPOND** AGAINST **CYBER SECURITY THREATS**. WE DIFFERENTIATE OURSELVES BY OFFERING **DISCREET, TAILORED** AND **SPECIALIZED** ENGAGEMENTS.

ELYSIUMSECURITY OPERATES IN **MAURITIUS** AND IN **EUROPE**, A **BOUTIQUE STYLE** APPROACH MEANS WE CAN **EASILY ADAPT** TO YOUR BUSINESS OPERATIONAL MODEL AND REQUIREMENTS TO PROVIDE A **PERSONALIZED SERVICE** THAT FITS YOUR WORKING ENVIRONMENT.

ELYSIUMSECURITY PROVIDES **HIGH LEVEL EXPERTISE** GATHERED THROUGH YEARS OF **BEST PRACTICES EXPERIENCE** IN LARGE INTERNATIONAL COMPANIES ALLOWING US TO PROVIDE ADVICE BEST SUITED TO YOUR **BUSINESS OPERATIONAL MODEL** AND **PRIORITIES**.

ELYSIUMSECURITY PROVIDES **PRACTICAL EXPERTISE** TO **IDENTIFY VULNERABILITIES**, ASSESS THEIR **RISKS** AND **IMPACT**, **REMEDiate** THOSE RISKS, **PREPARE** AND **RESPOND** TO INCIDENTS AS WELL AS RAISE **SECURITY AWARENESS** THROUGH AN ORGANIZATION.

